

CISSP Printable Practice Exam 07 - Domain 7 - Security Operations

Domain 7

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-117)

Scenario: A security analyst is investigating a compromised application server that remains powered on and connected to an isolated forensic network. The server contains active processes, network sessions, encryption keys in memory, and persistent storage that can be imaged.

Which action should the analyst take FIRST to preserve the most time-sensitive evidence?

- A. Create a bit-for-bit image of each persistent storage device
- B. Capture volatile memory and current system-state information
- C. Power off the server and document the shutdown time
- D. Reinstall the operating system on replacement storage

Question 2 (CISSP1-118)

Scenario: A regional financial services firm is redesigning its logging architecture after investigators were unable to correlate events across servers, network devices, and cloud workloads. Administrators on monitored systems can currently alter local logs.

Which THREE measures would MOST improve the reliability and investigative value of the firm's centralized logs? Select 3 of the 5 options below.

- A. Synchronize event sources to trusted time services
- B. Forward logs promptly to a restricted centralized repository
- C. Allow each system owner to define an independent timestamp format
- D. Protect stored logs with integrity monitoring and access controls
- E. Disable collection of successful authentication events to reduce volume

Question 3 (CISSP1-119)

Scenario: An internal administrative inquiry into misuse of a privileged account uncovers evidence suggesting deliberate theft of regulated customer data. Senior management may refer the matter to law enforcement.

What is the security manager's BEST next step?

- A. Continue informal interviews until the suspected employee admits responsibility
- B. Publish the evidence internally so affected departments can identify the individual
- C. Engage legal counsel and preserve evidence under documented forensic procedures
- D. Immediately delete the suspected account and all associated files

Question 4 (CISSP1-120)

Scenario: A manufacturing company provisions hundreds of nearly identical servers. Quarterly reviews repeatedly find unauthorized deviations from the approved secure configuration, and manual correction is slow and inconsistent.

Which improvement would BEST address the recurring operational problem?

- A. Use version-controlled configuration templates with automated drift detection and approved remediation
- B. Permit administrators to maintain personal configuration scripts on each server
- C. Replace configuration baselines with annual vulnerability scans
- D. Rebuild every server whenever any configuration difference is detected

Question 5 (CISSP1-121)

Scenario: Database administrators at an online retailer use permanently enabled shared administrator credentials for both routine work and emergency changes. Post-incident reviews cannot reliably attribute actions to individuals.

Which control would BEST reduce the risk while preserving necessary administrative capability?

- A. Rotate the shared password monthly and distribute it to all administrators
- B. Record only failed commands executed through the shared account
- C. Create separate shared accounts for routine and emergency work
- D. Issue named accounts with just-in-time elevation, approval, and session logging

Question 6 (CISSP1-122)

Scenario: A research organization is retiring failed solid-state drives that stored highly sensitive intellectual property. The drives cannot be reliably accessed to perform logical overwriting and will not be reused.

What is the MOST appropriate disposition method?

- A. Return the drives to general inventory after deleting their asset records
- B. Physically destroy the drives using an approved process and retain disposition records
- C. Quick-format the drives and donate them to another department
- D. Relabel the drives as unclassified before sending them to standard recycling

Question 7 (CISSP1-123)

Scenario: A hospital detects ransomware encrypting files on several workstations. Network telemetry indicates active lateral movement, while unaffected clinical systems remain available. The incident response plan has been activated.

Which TWO actions should the incident commander prioritize during initial containment?

Select 2 of the 5 options below.

- A. Isolate affected endpoints and restrict the observed lateral-movement paths
- B. Erase every affected endpoint before collecting incident data
- C. Preserve relevant volatile data, logs, and forensic evidence through authorized procedures
- D. Restore all affected endpoints immediately from the most recent available backup
- E. Delay internal reporting until the full root cause has been proven

Question 8 (CISSP1-124)

Scenario: A logistics provider has restored services after a credential-stuffing incident. The post-incident review identifies slow escalation, unclear ownership, and a detection rule that produced an excessive number of low-value alerts.

Which outcome would provide the GREATEST long-term value from the lessons-learned process?

- A. Archive the meeting notes without assigning further work
- B. Discipline the first analyst who handled the alert
- C. Keep the response plan unchanged to preserve procedural consistency
- D. Assign tracked improvements to the playbook, alert logic, ownership, and training

Question 9 (CISSP1-125)

Scenario: A media company discovers that a compromised internal workstation is sending encrypted outbound traffic to an unapproved external destination over a port that is normally allowed. Inbound firewall rules did not prevent the activity.

Which measure would MOST directly reduce the likelihood of similar exfiltration succeeding?

- A. Permit outbound connections only through controlled services and monitor destination behavior
- B. Increase the retention period for physical access badge records
- C. Move the workstation to a larger network segment
- D. Disable all inbound logging at the perimeter

Question 10 (CISSP1-126)

Scenario: A utility operates an isolated honeypot containing no legitimate user data. The monitoring team detects interactive access from an internal network address and observes commands consistent with reconnaissance.

What should the security operations team do FIRST?

- A. Add production credentials to the honeypot to learn which accounts the actor prefers
- B. Allow the honeypot unrestricted outbound access so the actor can be followed
- C. Validate and escalate the high-fidelity alert while preserving telemetry and containing related risk
- D. Ignore the event because honeypots are expected to receive unauthorized traffic

Question 11 (CISSP1-127)

Scenario: A critical vulnerability is being actively exploited. The affected internet-facing service supports revenue processing, and a vendor patch is available but has not completed normal regression testing. A tested network-level mitigation can temporarily block the known exploit path.

Which response BEST balances immediate risk reduction and service stability?

- A. Wait for the next routine maintenance window without changing any controls
- B. Apply the temporary mitigation, invoke emergency change procedures, test the patch, and deploy it promptly
- C. Install the patch immediately outside all change controls and without a rollback plan
- D. Permanently retire the revenue service before evaluating compensating controls

Question 12 (CISSP1-128)

Scenario: A system owner requests an urgent production change to resolve recurring performance failures. The technical modification has succeeded in a test environment, but its security impact and production reversal steps have not been documented.

What should the change authority require BEFORE approving implementation?

- A. Document security impact, implementation validation, authorization, and a tested rollback approach
- B. Obtain only the developer's verbal assurance that the change is low risk
- C. Skip post-implementation review because testing already succeeded
- D. Transfer permanent approval authority to the system owner

Question 13 (CISSP1-129)

Scenario: A professional services firm backs up production data continuously to storage reachable with the same administrative credentials used for production. During a ransomware incident, attackers encrypted both production data and the connected backup copies.

Which improvement would BEST address the demonstrated weakness?

- A. Increase backup frequency while retaining the shared credentials
- B. Store every backup exclusively on the production network
- C. Maintain isolated or immutable backup copies under separate access controls and test restoration
- D. Replace restoration testing with checks that backup jobs completed

Question 14 (CISSP1-130)

Scenario: A payment processor requires critical transaction services to resume within one hour of a primary-site loss. Management accepts the cost of continuously maintained duplicate infrastructure and near-real-time data replication.

Which recovery strategy BEST satisfies these requirements?

- A. A cold site with power and floor space but no installed processing equipment
- B. A warm site requiring hardware configuration and restoration from shipped media
- C. A reciprocal agreement to use another organization's spare capacity when available
- D. A mirrored site with synchronized systems and rapid failover capability

Question 15 (CISSP1-131)

Scenario: A public agency wants to demonstrate that its alternate processing environment can run recovered applications using restored data. The production environment must remain active and continue serving the public throughout the exercise.

Which TWO characteristics describe the MOST appropriate disaster recovery test? Select 2 of the 5 options below.

- A. Recovery systems are activated and operated alongside production systems
- B. Production processing is deliberately shut down and transferred completely
- C. The exercise is limited to reading the plan individually without discussion
- D. Restored processing is validated without making it the live production service
- E. Participants discuss actions around a table without activating recovery systems

Question 16 (CISSP1-132)

Scenario: An energy distributor proposes its first full interruption test for a critical business system. Walkthroughs and simulations have found unresolved recovery procedure gaps, and the business has not approved an outage window.

What should the security manager recommend?

- A. Proceed immediately because full interruption testing automatically corrects procedural gaps
- B. Resolve material gaps, obtain business authorization, define rollback criteria, and then schedule the test
- C. Cancel all future recovery exercises because critical systems should not be tested
- D. Perform the interruption without notifying system owners to make the test more realistic

Question 17 (CISSP1-133)

Scenario: A food distributor depends on one external logistics provider for time-sensitive deliveries. The business continuity plan states that staff will switch to an alternate provider during a regional disruption, but the alternate has never participated in an exercise.

Which action would provide the MOST useful assurance?

- A. Conduct an exercise that validates contacts, capacity, data exchange, decision authority, and the alternate workflow

- B. Assume the alternate provider can accept the workload because a contract exists
- C. Test only the security team's incident notification tree
- D. Remove logistics from the continuity plan because the service is outsourced

Question 18 (CISSP1-134)

Scenario: A biotechnology company has strong perimeter access control, but employees from unrestricted office areas can enter a sensitive laboratory by following an authorized worker through an internal door. Investigations show that the door does not reliably latch and no alert is generated when it remains open.

Which improvement would BEST address the immediate physical security weakness?

- A. Add more exterior landscaping around the building
- B. Require stronger passwords for laboratory workstations
- C. Install controlled individual entry with door-position monitoring and anti-tailgating procedures
- D. Extend visitor parking farther from the main entrance

Question 19 (CISSP1-135)

Scenario: A branch employee who handles sensitive records may be forced by an aggressor to request after-hours access. The organization wants a control that alerts responders without requiring the employee to openly resist or escalate the confrontation.

Which control BEST meets the objective?

- A. A rehearsed duress signal that silently alerts designated responders under a documented safety procedure
- B. A policy requiring the employee to physically prevent access in every circumstance
- C. A public announcement identifying the employee and suspected aggressor
- D. A quarterly report listing all ordinary after-hours access requests

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-117) - Correct: B

Volatile memory and live system-state data can disappear when power is removed or system activity changes, so they should be captured before persistent storage is imaged. A disk image remains important but is less volatile. Powering off the server would destroy memory-resident evidence, and reinstalling the system is a recovery action that could overwrite evidence rather than preserve it.

Question 2 (CISSP1-118) - Correct: A, B, D

Trusted time synchronization, prompt centralized forwarding, and integrity-protected restricted storage make events easier to correlate and harder for a compromised local administrator to alter. Independent timestamp conventions impede correlation. Successful authentication records often provide essential context for account misuse and should not be categorically discarded merely to reduce volume.

Question 3 (CISSP1-119) - Correct: C

Because the inquiry may become criminal and involves regulated data, legal counsel should guide escalation while investigators preserve evidence with documented, repeatable procedures and chain-of-custody records. Informal interviews could compromise the inquiry, broad publication violates need-to-know, and deleting account data risks destroying evidence. Account access may need containment, but evidence preservation must be coordinated first.

Question 4 (CISSP1-120) - Correct: A

Version-controlled templates establish an authoritative baseline, while automated drift detection and approved remediation provide consistent enforcement at scale. Personal scripts weaken control and traceability. Vulnerability scans do not replace configuration management, and rebuilding every server is disproportionate and may disrupt service without addressing the change-control weakness.

Question 5 (CISSP1-121) - Correct: D

Named accounts with time-limited elevation, approval, and session logging minimize standing privilege while supporting attribution and oversight. Rotating or subdividing shared credentials still prevents individual accountability. Recording only failures omits successful actions, which are often the events most important to an investigation.

Question 6 (CISSP1-122) - Correct: B

Approved physical destruction is appropriate when highly sensitive solid-state media cannot be reliably sanitized and will not be reused; disposition records maintain accountability. Quick formatting does not reliably remove data. Relabeling changes neither the data nor its sensitivity, and deleting asset records before controlled disposition breaks lifecycle tracking.

Question 7 (CISSP1-123) - Correct: A, C

Initial containment should limit further spread while preserving evidence needed to determine scope and cause. Immediate erasure destroys evidence. Restoration belongs to recovery and should follow containment and validation of clean backups. Reporting should follow the response plan and applicable obligations; it should not wait for perfect certainty about root cause.

Question 8 (CISSP1-124) - Correct: D

Lessons learned create value when findings become owned, tracked improvements to people,

process, and technology. Archiving notes alone does not reduce recurrence. Blaming one analyst ignores systemic weaknesses, and preserving a demonstrably weak plan sacrifices improvement for superficial consistency.

Question 9 (CISSP1-125) - Correct: A

Controlled egress paths, destination restrictions, and outbound monitoring directly address unauthorized exfiltration even when traffic uses an ordinarily permitted port. Badge retention does not control network transfer. A larger segment can increase exposure, and disabling inbound logging reduces visibility without constraining outbound activity.

Question 10 (CISSP1-126) - Correct: C

Legitimate users should not interact with the honeypot, so internal interactive access is a high-value signal that should be validated, escalated, preserved, and investigated for related compromise. Adding real credentials creates unnecessary exposure. Unrestricted outbound access could let the system harm others, while ignoring the event wastes the primary purpose of the deception control.

Question 11 (CISSP1-127) - Correct: B

A validated compensating control can reduce immediate exposure while emergency change procedures accelerate testing and deployment of the durable fix. Waiting leaves an actively exploited service exposed. Uncontrolled installation can create avoidable outages, and permanent retirement is disproportionate when effective mitigation and remediation paths exist.

Question 12 (CISSP1-128) - Correct: A

A controlled production change requires assessed security impact, defined validation, appropriate authorization, and a viable rollback method. A verbal assurance is not sufficient evidence. Test success does not remove the need to verify production results, and the system owner should not receive unrestricted authority that bypasses governance and separation of duties.

Question 13 (CISSP1-129) - Correct: C

Isolated or immutable copies with separate administrative controls limit an attacker's ability to destroy recovery data, while restoration tests confirm that the copies are usable. More frequent backups remain vulnerable if the same compromise can reach them. Production-only storage lacks isolation, and successful job status does not prove recoverability.

Question 14 (CISSP1-130) - Correct: D

A mirrored site provides the continuously maintained infrastructure and synchronized data needed for a very short recovery time objective. Cold and warm sites require substantial activation and restoration time. A reciprocal agreement may lack guaranteed capacity and typically cannot assure the readiness required for critical transaction processing.

Question 15 (CISSP1-131) - Correct: A, D

A parallel test activates recovery resources and validates restored processing while the production environment continues to operate. Completely shutting down and transferring production describes a full interruption test. Individual reading and discussion-based exercises provide less operational assurance because they do not activate the recovery systems.

Question 16 (CISSP1-132) - Correct: B

A full interruption test can provide strong assurance but also creates real operational

risk. Material deficiencies should be corrected, accountable business owners must authorize the outage, and rollback and stop criteria should be established before proceeding. An interruption does not fix gaps by itself, permanent avoidance leaves recovery unvalidated, and an unannounced disruption lacks responsible authorization.

Question 17 (CISSP1-133) - Correct: A

A realistic exercise should validate that the alternate arrangement works end to end, including capacity, communications, information exchange, authority, and operational procedures. A contract alone does not prove readiness. Testing only security notifications misses the business process, while outsourcing transfers service delivery but not the organization's continuity responsibility.

Question 18 (CISSP1-134) - Correct: C

Controlled individual entry, reliable door-state monitoring, and anti-tailgating procedures directly address unauthorized passage from a general area into the restricted laboratory. Landscaping and parking changes focus on the outer perimeter, not the internal boundary. Strong workstation passwords are useful logical controls but do not prevent unauthorized physical entry.

Question 19 (CISSP1-135) - Correct: A

A discreet, rehearsed duress signal can summon an appropriate response while prioritizing the employee's safety and avoiding overt escalation. Requiring physical resistance increases danger. A public announcement could provoke the aggressor, and retrospective reporting cannot provide immediate assistance during a coercion event.